

AI READINESS & RISK ASSESSMENT - RESULTS REPORT

Grant Thornton Bahrain | Professional services | Assessment date: 04/10/2026

Scope: Whole organisation - Firm-wide AI adoption across Audit, Tax, Advisory and internal functions | Completed by: AI Service Line Lead (Director, Risk Advisory)
Framework basis: NSW AI Assessment Framework (inherent risk) | ISO/IEC 42001, ISO/IEC 23894, NIST AI RMF | EU AI Act, Bahrain PDPL | GT AI RCM v2.1 (controls)

1. EXECUTIVE SUMMARY			
OVERALL AI READINESS	MATURITY LEVEL	INHERENT RISK TIER	OVERALL AI RISK EXPOSURE
59%	Informed	Medium	Moderate
Maturity scale: <50% Partial 50-70% Informed 70-90% Repeatable 90%+ Adaptive	Awareness and some defined practices exist, but they are not consistently implemented.	43% of maximum inherent risk. No override applied	Combines inherent risk tier and readiness maturity (see Methodology)

RECOMMENDED PATHWAY	PROCEED WITH CONDITIONS
Continue AI adoption, but address the identified gaps through a time-bound remediation plan (within 90 days for priority items). Obtain SME review (risk, privacy, security) for new AI use cases.	

Based on the responses provided, Grant Thornton Bahrain has an overall AI readiness score of 59%, corresponding to the 'Informed' maturity level: awareness and some defined practices exist, but they are not consistently implemented. Its AI use profile indicates a MEDIUM inherent risk tier (43% of maximum inherent risk), resulting in an overall AI risk exposure rating of MODERATE. The strongest area is Training & Awareness (75%) and the area requiring most attention is AI Risk & Security (50%). Recommended pathway: PROCEED WITH CONDITIONS. Continue AI adoption, but address the identified gaps through a time-bound remediation plan (within 90 days for priority items). Obtain SME review (risk, privacy, security) for new AI use cases.

2. READINESS BY DOMAIN			
Domain	Score	Maturity	Progress
AI Governance	63%	Informed	
AI Risk & Security	50%	Informed	
Training & Awareness	75%	Repeatable	
Strategy & Value	50%	Informed	
Data & Technology	58%	Informed	
OVERALL	59%	Informed	Target 70%

Domain	Score	Maturity
Governance	63%	Informed
Risk & Security	50%	Informed
Training	75%	Repeatable
Strategy	50%	Informed
Data & Tech	58%	Informed
OVERALL	59%	Informed

Domain	Potential risk if the domain is not strengthened (shown where score < 90%)
AI Governance	Without clear accountability, policy, oversight and assurance, AI is adopted inconsistently, misused and breaches regulation without anyone noticing or answering for it.
AI Risk & Security	Without an AI risk framework, risk appetite, impact assessments, third-party controls and AI security, the organisation is exposed to unmanaged AI risk, prompt injection, data leakage, model compromise and deepfake-enabled fraud.
Training & Awareness	Low AI literacy and awareness increase unsafe use of AI tools, unchecked or biased outputs and susceptibility to AI-enabled phishing and deepfakes.
Strategy & Value	Without clear direction, ownership and value tracking, AI adoption is fragmented, duplicated and hard to justify.
Data & Technology	Weak data governance, architecture and model validation lead to inaccurate or biased outputs, privacy breaches, undetected drift and unsustainable costs.

3. AI USE & INHERENT RISK PROFILE (AIAF-based)			
Factor	Your response	Risk level	Implication
A1 AI use profile	Approved enterprise GenAI tools and AI features embedded in business software across teams	Medium	AI is part of day-to-day work. Exposure spans data protection, output quality, vendor dependence and consistent human review.
A2 Decision impact	Customer- or client-facing outputs with limited individual impact (e.g., FAQ chatbots, marketing content)	Medium	External stakeholders see AI outputs - disclosure, accuracy and reputational controls apply (e.g., EU AI Act Art. 50 where relevant).
A3 Data sensitivity	Confidential business or client information	Medium	Confidentiality and contractual obligations apply; vendor data-use terms are critical.
A4 Oversight & reversibility	A qualified human reviews and approves every AI output before it is used	Low	Effective 'human-in-charge' control if reviewers are trained and have time and authority to challenge.
Inherent risk tier: MEDIUM (43% weighted inherent-risk score)		No override applied	

4. RESPONSIBLE-AI PRINCIPLE COVERAGE (NSW AIAF ethics principles)			
Principle	Coverage	Assessment	Informed by questions
Fairness	58%	Partially addressed	Q7, Q18, Q20
Privacy & Security	65%	Partially addressed	Q6, Q12, Q13, Q14, Q18
Transparency & Explainability	63%	Partially addressed	Q7, Q8
Accountability	53%	Partially addressed	Q5, Q6, Q8, Q9, Q10, Q11, Q12, Q16
Human, Social & Environmental Wellbeing	50%	Partially addressed	Q11, Q17
Human-Centred Values	63%	Partially addressed	Q7, Q15
Reliability & Safety	50%	Partially addressed	Q8, Q9, Q13, Q19, Q20
Contestability	63%	Partially addressed	Q7, Q8

5. DETAILED FINDINGS & RECOMMENDATIONS

Area	Your response & score	Potential risk	Recommended action
Q5 AI governance structure & accountability AI Governance  Mandatory Requirement	50% - Partially met AI committee or sponsor defined on paper; roles and decision rights partly documented	Unclear accountability for AI decisions and outcomes, inconsistent approvals and no escalation route when AI fails.	Assign named business and technical owners to every AI system and publish a RACI across the three lines of defence. Controls: GL-1, GL-2, GL-7, AA-1
Q6 AI policy, acceptable use & regulatory compliance AI Governance  Compliance Obligation	75% - Largely met AI policy enforced with staff acknowledgement; obligations register maps regulations to controls and owners	Misuse of AI, data leakage and breach of legal or regulatory requirements, with exposure to penalties, licence conditions and reputational harm.	Establish monthly regulatory horizon scanning and periodic compliance testing with evidence retention. Controls: GL-5, RO-1, RO-5
Q7 Responsible-AI guardrails & human oversight AI Governance  Ethical Consideration	50% - Partially met AI committee / CoE established; guardrails defined for some areas (e.g., human review of outputs)	Biased or harmful outcomes, undisclosed AI use and lack of accountability for AI-supported decisions.	Apply mandatory human-in-charge controls and AI disclosure to all relevant AI; require committee approval for High / Critical uses. Controls: GL-7, RS-1, RS-4, RS-5, CO-1, CO-3
Q8 AI incidents, monitoring & assurance AI Governance  Compliance Obligation	75% - Largely met AI incident management with regulatory notification criteria; periodic internal audit of AI governance; assurance obtained from AI vendors	Delayed response to AI failures, missed regulatory notifications and lack of defensible evidence for regulators, auditors and clients.	Implement post-incident learning and an ISO/IEC 42001 certification-readiness review. Controls: IM-1, IM-2, IM-3, AA-1, AA-2, RO-4
Q9 AI risk management framework AI Risk & Security  Mandatory Requirement	25% - Minimal AI risks considered informally within general IT or project risk	AI risks go unidentified or are rated inconsistently, so high-risk AI is approved without proportionate controls.	Formalise the methodology, approve it at executive level and pilot it on current AI initiatives. Controls: RM-1, RM-2, RM-3, RM-5
Q10 AI risk appetite, KRIs & reporting AI Risk & Security  Mandatory Requirement	50% - Partially met AI risk appetite drafted; a few indicators tracked informally	No shared view of how much AI risk is acceptable - leading to reckless adoption or blocked innovation - and late detection of deteriorating AI risk.	Define KRIs with thresholds and escalation for each risk category and report them to the AI committee quarterly. Controls: RM-6, RM-4, GL-1
Q11 AI inventory & risk / impact assessment AI Risk & Security  Mandatory Requirement	50% - Partially met AI register with owners; risk assessments performed for some AI systems using a documented method	Deployment of vulnerable, non-compliant or harmful AI systems and unknown AI exposure across the organisation and its supply chain.	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier. Controls: GL-8, RM-2, RM-5, TP-2
Q12 Third-party & AI supply-chain risk AI Risk & Security  Compliance Obligation	50% - Partially met AI questions added to vendor due diligence for some purchases; contract terms vary	Client or personal data used to train vendor models, unmanaged model changes, concentration on a single provider and regulatory breaches through suppliers.	Make AI due diligence mandatory and adopt standard AI contract clauses (no training on client data, residency, audit, incident notice). Controls: TP-1, TP-2, TP-3, SE-7, LC-6
Q13 Securing AI systems AI Risk & Security  Mandatory Requirement	50% - Partially met AI-specific threats (e.g., prompt injection, data leakage) assessed for some systems; access controls and logging in place	Unauthorised access, model compromise, data exfiltration through AI and undetected misuse.	Introduce AI red teaming before release, runtime guardrails (input / output filtering) and audit logging. Controls: SE-2, SE-3, SE-6 to SE-10, OM-2, AA-3

Q14 Defending against AI-enabled threats AI Risk & Security ☆ Recommended	75% - Largely met Deepfake-resilient verification for payments and sensitive requests; behaviour-based detection; AI incident playbooks exercised	Deepfake-enabled fraud, account compromise and faster, more scalable attacks that outpace defences.	Adopt continuous exposure management and AI-specific red teaming; reduce patch cycles to days. Controls: AT-1, AT-2, AT-3, AT-4
Q15 AI training, literacy & awareness Training & Awareness 🔗 Compliance Obligation	75% - Largely met Mandatory AI literacy before tool access; role-based pathways for developers, oversight staff and leaders; scenario-based security awareness	Unsafe use, susceptibility to AI-enabled threats and poor adoption; non-compliance with the EU AI Act Art. 4 AI-literacy duty where applicable.	Measure competence, refresh annually, and build an AI champions network and workforce plan. Controls: GL-4, RS-9
Q16 AI strategy & executive ownership Strategy & Value ☆ Recommended	50% - Partially met Executive sponsor named and AI strategy drafted, but not linked to business objectives or budget	Lack of executive direction leads to inconsistent AI use, unmanaged risk-taking, poor-quality outputs and fragmented adoption.	Link the strategy to business objectives and budget; define experimentation ('sandbox') boundaries and communicate them. Controls: GL-1, GL-3
Q17 Use-case portfolio & value realisation Strategy & Value ☆ Recommended	50% - Partially met Use-case intake exists and initiatives are prioritised, but benefits are not systematically tracked	Duplicated or low-value AI investment, shadow AI and inability to demonstrate return on investment.	Define benefit KPIs (financial and non-financial) at approval and assign benefit owners. Controls: GL-6, GL-5
Q18 Data governance, quality & privacy for AI Data & Technology 🔗 Compliance Obligation	75% - Largely met Data readiness assessed before approval; lineage and quality monitored; minimisation, anonymisation and prompt redaction applied; DPIAs standard	Data breaches, PDPL non-compliance, and biased or inaccurate outputs from poor-quality or unsuitable data.	Automate data-quality and lineage monitoring; operationalise data-subject rights and transfer assessments for AI. Controls: LC-1, SE-4, PR-1, PR-4, PR-5, PR-6
Q19 AI architecture, integration & monitoring Data & Technology ☆ Recommended	50% - Partially met Reference architecture drafted; approved platforms and integration patterns for most AI; basic performance monitoring	Inconsistent and insecure implementations, undetected model drift or failure, excessive agent privileges and unsustainable AI costs.	Centralise API / access control for AI, define agent execution authority and implement drift / performance monitoring with thresholds. Controls: LC-2, LC-3, LC-8, LC-12, OM-1, OM-4, RM-6
Q20 Model risk management & validation Data & Technology ☆ Recommended	50% - Partially met Model inventory exists; validation performed for some material models	Inaccurate, biased or unstable models drive decisions unnoticed, with regulatory exposure for financial-services clients.	Validate all material models before use and on a risk-based cycle; document thresholds, limitations and conditions of use. Controls: LC-9, RS-6, LC-13, OM-1

6. TOP 5 PRIORITY ACTIONS

Ranked by size of gap, weighted for compliance / mandatory requirements and the organisation's inherent risk tier.

#	Area	Score	Action	Timing
1	AI risk management framework	25%	Formalise the methodology, approve it at executive level and pilot it on current AI initiatives.	Immediate (0-3 months)
2	AI governance structure & accountability	50%	Assign named business and technical owners to every AI system and publish a RACI across the three lines of defence.	Immediate (0-3 months)
3	AI risk appetite, KRIs & reporting	50%	Define KRIs with thresholds and escalation for each risk category and report them to the AI committee quarterly.	Immediate (0-3 months)

4	AI inventory & risk / impact assessment	50%	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier.	Immediate (0-3 months)
5	Third-party & AI supply-chain risk	50%	Make AI due diligence mandatory and adopt standard AI contract clauses (no training on client data, residency, audit, incident notice).	Immediate (0-3 months)

7. SUGGESTED IMPLEMENTATION ROADMAP

Horizon	Area	Action	Controls
Immediate (0-3 months)	AI risk management framework	Formalise the methodology, approve it at executive level and pilot it on current AI initiatives.	RM-1, RM-2, RM-3, RM-5
Immediate (0-3 months)	AI governance structure & accountability	Assign named business and technical owners to every AI system and publish a RACI across the three lines of defence.	GL-1, GL-2, GL-7, AA-1
Immediate (0-3 months)	AI risk appetite, KRIs & reporting	Define KRIs with thresholds and escalation for each risk category and report them to the AI committee quarterly.	RM-6, RM-4, GL-1
Immediate (0-3 months)	AI inventory & risk / impact assessment	Extend assessments to all AI systems and third-party AI; set approval authority by risk tier.	GL-8, RM-2, RM-5, TP-2
Immediate (0-3 months)	Third-party & AI supply-chain risk	Make AI due diligence mandatory and adopt standard AI contract clauses (no training on client data, residency, audit, incident notice).	TP-1, TP-2, TP-3, SE-7, LC-6
Immediate (0-3 months)	Securing AI systems	Introduce AI red teaming before release, runtime guardrails (input / output filtering) and audit logging.	SE-2, SE-3, SE-6 to SE-10, OM-2, AA-3
Short term (3-6 months)	Responsible-AI guardrails & human oversight	Apply mandatory human-in-charge controls and AI disclosure to all relevant AI; require committee approval for High / Critical uses.	GL-7, RS-1, RS-4, RS-5, CO-1, CO-3
Short term (3-6 months)	AI strategy & executive ownership	Link the strategy to business objectives and budget; define experimentation ('sandbox') boundaries and communicate them.	GL-1, GL-3
Short term (3-6 months)	Use-case portfolio & value realisation	Define benefit KPIs (financial and non-financial) at approval and assign benefit owners.	GL-6, GL-5
Short term (3-6 months)	AI architecture, integration & monitoring	Centralise API / access control for AI, define agent execution authority and implement drift / performance monitoring with thresholds.	LC-2, LC-3, LC-8, LC-12, OM-1, OM-4, RM-6
Short term (3-6 months)	Model risk management & validation	Validate all material models before use and on a risk-based cycle; document thresholds, limitations and conditions of use.	LC-9, RS-6, LC-13, OM-1
Medium term (6-12 months)	AI policy, acceptable use & regulatory compliance	Establish monthly regulatory horizon scanning and periodic compliance testing with evidence retention.	GL-5, RO-1, RO-5
Medium term (6-12 months)	AI incidents, monitoring & assurance	Implement post-incident learning and an ISO/IEC 42001 certification-readiness review.	IM-1, IM-2, IM-3, AA-1, AA-2, RO-4
Medium term (6-12 months)	AI training, literacy & awareness	Measure competence, refresh annually, and build an AI champions network and workforce plan.	GL-4, RS-9
Medium term (6-12 months)	Data governance, quality & privacy for AI	Automate data-quality and lineage monitoring; operationalise data-subject rights and transfer assessments for AI.	LC-1, SE-4, PR-1, PR-4, PR-5, PR-6
Medium term (6-12 months)	Defending against AI-enabled threats	Adopt continuous exposure management and AI-specific red teaming; reduce patch cycles to days.	AT-1, AT-2, AT-3, AT-4

8. REGULATORY & STANDARDS CONSIDERATIONS

Applicability is based on the Profile answers; the readiness signal uses the most relevant question scores. Not legal advice - confirm obligations with legal counsel.

Law / regulation / standard	Applies?	Readiness signal	Key considerations
Bahrain Personal Data Protection Law (Law No. 30 of 2018)	Yes	Partial gap	Lawful basis and notice for AI processing; DPIAs; security; data-subject rights incl. objection to automated processing; cross-border transfer rules for AI services hosted outside Bahrain (RCM PR-1 to PR-6).
iGA General Policy for the Use of AI (2025) & GCC Guiding Manual on the Ethics of AI Use	Reference	Partial gap	National AI policy pillars (compliance, adoption, awareness, cooperation) and GCC ethics principles - mandatory reference for government entities and good practice for all (RCM GL-1, GL-4, RS-series).
Central Bank of Bahrain Rulebook (HC, RM, OM, BC modules)	No	Partial gap	Board oversight, risk management, cyber security, outsourcing and consumer-protection requirements apply to AI; expect model validation for material models and notification of material outsourcing (RCM LC-9, TP-3, AT-3).
EU AI Act (Regulation 2024/1689) - general obligations	Yes	On track	Extraterritorial reach. Prohibited practices (Art. 5) and AI literacy (Art. 4) apply since Feb 2025; GPAI rules since Aug 2025; transparency (Art. 50) from Aug 2026 (RCM RM-5, GL-4, CO-1, LC-7).
EU AI Act - high-risk AI systems (Annex III)	Check	Significant gap	Decisions on credit, employment, insurance, essential services etc. may be high-risk: risk management, data governance, logging, human oversight, FRIA and registration (timelines subject to the EU Digital Omnibus outcome) (RCM RO-6).
KSA / UAE / GCC regimes (SDAIA AI Ethics, KSA PDPL, UAE AI Charter, DIFC Regulation 10, QCB AI Guideline)	Yes	Partial gap	Include in the AI obligations register; align data-transfer, ethics and sector AI requirements across GCC operations (RCM RO-5).
ISO/IEC 42001:2023 AI management system	Build first	Significant gap	International certifiable standard for AI governance; demonstrates trustworthy AI to clients and regulators. Recommended once readiness reaches 'Repeatable' (RCM AA-2).
Bahrain draft AI Regulation Law (Shura Council, 2024)	Monitor	On track	Proposed standalone AI law (38 articles) with a new regulator and penalties - not yet in force. Maintain horizon scanning (RCM RO-5).

9. HOW GRANT THORNTON CAN HELP

GT AI service line	Relevance	How we help
AI Governance, Risk & Compliance	Advised	AI governance structure, policies and acceptable use, AI register, guardrails and human-oversight standards, RCM-based compliance reviews, ISO/IEC 42001 readiness and internal audit.
AI Risk & Cyber Resilience	Advised	AI risk management framework and risk appetite, use-case risk & impact assessments, third-party AI risk, AI security audits (GT AI Security & Agent Audit Checklist), AI red teaming, deepfake-resilient processes.
Training & Awareness	Optional	AI literacy programmes (EU AI Act Art. 4-aligned), role-based pathways, immersive labs, deepfake & AI-phishing simulations, board AI governance sessions.
AI Strategy & Roadmap	Advised	AI Opportunity Discovery (where AI and automation fit), AI strategy, use-case prioritisation, value-realisation KPIs and phased roadmap.
AI-Driven Automation & Data	Advised	Technology evaluation, data readiness, reference architecture, model validation and integration. GT AI apps in preparation: AI-powered BCP tool and AI-powered Financial Statements tool.

10. NEXT STEPS & SIGN-OFF

- 1. Review this report with the executive sponsor and AI / risk committee.
- 2. Validate responses with evidence (the level selected should be demonstrable).
- 3. Assign owners and dates in the '4. Action Plan' sheet for all Immediate and Short-term actions.
- 4. For individual AI systems rated High or Critical, perform a use-case risk assessment (GT AI Risk Assessment Toolkit).
- 5. Re-run this assessment in 6-12 months or after significant AI adoption or regulatory change to track progress.

Role	Name	Signature	Date
Assessment completed by	AI Service Line Lead		
Reviewed by (risk / compliance)			
Executive sponsor			

Methodology: Part A (4 questions) derives an inherent-risk tier from the NSW AI Assessment Framework risk factors (AI use, decision impact, data sensitivity, oversight & reversibility). Part B (16 questions) scores readiness 0-100% across 5 domains (AI Governance; AI Risk & Security; Training & Awareness; Strategy & Value; Data & Technology); domain scores are averaged equally into the overall score and mapped to a four-band maturity scale. Exposure combines tier and maturity. Recommendations reference the GT AI RCM v2.1 controls. Disclaimer: this is a self-assessment based on the responses provided and has not been independently verified by Grant Thornton. It is not an audit, certification or legal opinion. (c) 2026 Grant Thornton Bahrain. All rights reserved.